

Vendor Risk Management Framework - Executive Summary

Gravity Payments, Inc. | June 2026

Field	Detail
Prepared by	Information Security and Compliance Team
Report Date	June 2026
Framework Version	1.0
Vendors Assessed	15 third-party vendors across 8 service categories
Regulatory Scope	PCI DSS v4.0 · GLBA Safeguards Rule · SOC 2 · CCPA/CPRA
Classification	Internal - Confidential - MOCK

Purpose of This Framework

Gravity Payments processes card transactions for tens of thousands of small and mid-sized businesses across the United States. Every vendor Gravity relies on to deliver that service introduces potential operational, security, and compliance risk. This Vendor Risk Management (VRM) Framework provides a structured, repeatable methodology for identifying, scoring, tiering, and monitoring that risk.

A payment processor is only as secure as its least-protected vendor. This framework ensures Gravity can identify its weakest links before they become incidents.

The framework was built using real-world GRC methodology, with direct mapping to the regulatory requirements Gravity operates under as a payment processor. Every score, every tier assignment, and every remediation item reflects a genuine risk a company in Gravity's position

would face.

Portfolio Snapshot - 15 Vendors Assessed

Metric	Count
Total Vendors Assessed	15
Critical Risk Vendors	0
High Risk Vendors	2
Medium Risk Vendors	7
Low Risk Vendors	6
Open Remediation Items	8
P1 Items (Immediate Action)	2
Overdue Assessments	1
Assessments In Progress	1

Sources: Vendor Risk Register tab (tier counts, assessment status); Remediation Tracker tab (open items, priorities).

Vendor Tier Distribution

Vendors are assigned to one of four risk tiers based on a composite score derived from inherent risk factors (data sensitivity, operational dependency, regulatory exposure) combined with control effectiveness (vendor security posture and contract protections). Higher composite scores indicate greater risk requiring more intensive oversight. The formula rewards strong controls: a vendor with high inherent risk but excellent security posture and contractual protections can score in a lower tier than its raw data access profile would suggest.

Tier	Count	Vendor Examples and Treatment
CRITICAL	0	No vendors currently score ≥ 10 . Core payment-rail vendors (Visa, Mastercard, AWS, Fiserv, Stripe) carry high inherent risk but hold strong certifications and contractual protections that reduce composite scores below the Critical threshold.
HIGH	2	Fiserv (8.0) - acquiring bank connectivity with a known IR notification gap. Unnamed Pentest Firm (9.0) - lapsed SOC 2 with privileged CDE access and weak contract protections. Both require active remediation.
MEDIUM	7	Visa, Mastercard, AWS, Stripe Issuing, Salesforce, Plaid, Experian. Significant inherent risk offset by strong vendor security posture. Standard annual assessment cycle with active monitoring.
LOW	6	Twilio, DocuSign, Zendesk, Okta, Slack, Checkr. Low composite scores driven by limited data access, limited operational dependency, or sufficiently strong controls to reduce residual risk below the Medium threshold. Okta is the key illustration of the last path: OD=4 (maximum) but SP=1 and CP=1 produce a Control Score of 1.00, yielding a composite of 3.33. The methodology rewards strong controls, even for operationally critical vendors.

Scoring Methodology

The framework uses a five-factor composite scoring model that separates inherent risk from control effectiveness, then multiplies the two scores together. Multiplication - not averaging - is intentional: a high-risk vendor with weak controls receives a non-linear risk escalation that averaging would understate.

Inherent Risk Factors (scored 1–4, averaged)

Factor	Description
Data Sensitivity	What category of data does the vendor access? Scale: 1 = No data, 4 = Cardholder data and encryption keys.

Factor	Description
Operational Dependency	What happens to payment processing if this vendor fails? Scale: 1 = Easily replaced, 4 = Single point of failure.
Regulatory Exposure	Which compliance frameworks require oversight of this vendor? Scale: 1 = None, 4 = Directly in PCI CDE scope.

Control Effectiveness Factors (scored 1–4, averaged; reversed scale - 1 is strongest)

Factor	Description
Security Posture	What third-party validation does the vendor hold? Scale: 1 = SOC 2 Type II + PCI certified, 4 = No evidence provided.
Contract Protections	Does Gravity have the contractual tools to enforce and investigate? Scale: 1 = Full DPA, SLA, audit rights, 4 = Click-wrap ToS only.

Composite Score Formula: Inherent Risk Score × Control Score | Range: 1–16

Tier Thresholds: Critical ≥ 10 · High 7–9.9 · Medium 4–6.9 · Low < 4

Key Findings and Open Remediation Items

Eight open remediation items were identified. Two are Priority 1 and require immediate action.

ID	Vendor	Pri.	Finding	Target	Status
REM-001	Unnamed Pentest Firm	P1	Pentest vendor SOC 2 certification has lapsed. PCI DSS Req 11.4 violation risk if not remediated before next	Sep 2026	AT RISK

ID	Vendor	Pri.	Finding	Target	Status
			QSA audit. Remediation target (Sep 2026) has not passed, but the expired cert creates active compliance exposure now.		
REM-002	Fiserv	P1	IR notification window is 72h. PCI DSS and card brand rules require notification within 24h of confirmed breach.	Sep 2026	In Progress
REM-003	Zendesk	P2	Partial PANs appearing in support ticket text. Creates PCI scope creep risk.	Jul 2026	In Progress
REM-004	Slack	P2	Card numbers shared in internal Slack channels. Requires DLP	Jul 2026	In Progress

ID	Vendor	Pri.	Finding	Target	Status
			deployment to prevent CDE scope expansion.		
REM-005	Salesforce	P2	Merchant SSNs and EINs stored in plain-text custom fields. Requires Shield Platform Encryption.	Aug 2026	Pending
REM-006	Okta	P2	Admin accounts not yet enrolled in phishing-resistant MFA (WebAuthn). Current TOTP insufficient for privileged access.	Aug 2026	In Progress
REM-007	Twilio	P3	SIM-swap attack risk for high-value merchants not mitigated. Twilio Verify Fraud Guard not yet deployed.	Sep 2026	Pending

ID	Vendor	Pri.	Finding	Target	Status
REM-008	Plaid	P3	CFPB Section 1033 open banking rule impact on existing DPA not yet assessed. Risk at effective date.	Oct 2026	Pending

Regulatory Framework Alignment

The framework satisfies the vendor oversight requirements of the following regulations, each of which applies directly to Gravity's operations:

Framework	Applicability
PCI DSS v4.0	Requirements 12.8 (third-party risk program), 12.8.2 (written agreements), 12.8.4 (annual monitoring), 11.4 (penetration testing). The framework's scoring model, DDQ, and remediation tracker are designed to produce evidence for these requirements.
GLBA Safeguards Rule	16 CFR Part 314 requires financial institutions to oversee service providers through written contracts and monitoring. DDQ sections on contract protections and data handling map directly to Safeguards Rule Section 314.4(f).
SOC 2 (AICPA)	Gravity's own SOC 2 examination includes vendor management as a control. Vendor SOC 2 reports are the primary assurance artifact used in the scoring model's Security Posture factor.
CCPA/CPRA	Gravity processes merchant data for California-resident business owners, making it subject to California's Consumer Privacy Act and its CPRA amendments. California merchants' personal data (contact info, EINs, SSNs used in underwriting)

Framework	Applicability
	triggers processor obligations. DDQ Section C enforces DPA requirements before vendor onboarding.
CFPB Section 1033	Emerging open banking rule creates new obligations for data aggregators such as Plaid. Monitored proactively as REM-008 to prevent non-compliance at effective date.

Framework Deliverables

Deliverable	Contents
Excel Workbook	Six-tab workbook: Cover Sheet, Scoring Methodology, Vendor Risk Register (15 vendors with live formulas and conditional formatting), Risk Heat Map, Due Diligence Questionnaire (35 questions across 7 sections), Remediation Tracker.
Executive Summary	This document. Overview suitable for sharing with recruiters, hiring managers, and compliance leadership.

GRC Competencies Demonstrated

Competency	Evidence
Third-Party Risk Management (TPRM)	Vendor tiering, due diligence questionnaire design, risk register maintenance
PCI DSS v4.0 Application	Requirement mapping, CDE scoping, evidence collection methodology
Risk Scoring Methodology	Inherent vs. residual risk, quantitative scoring, composite formula design
Regulatory Mapping	Cross-framework alignment across PCI DSS, GLBA, SOC 2, state privacy law

Competency	Evidence
Incident Response Integration	IR notification requirements, escalation paths, contractual SLA enforcement
Control Assessment	SOC 2 report evaluation, security posture scoring, control gap identification

Gravity Payments · Vendor Risk Management Framework · June 2026

Portfolio project. All vendor data and scores are hypothetical assumptions for demonstration purposes. Version 1.0.